University of Derby – Mediterranean College

Security Management

6CM508

01 Assessment 2025/2026

# University Assignment Report

**Prepared By:**

**Student ID**

100735054

100735054@unimail.derby.ac.uk

**12 January 2026**

# Table of Contents


**1. SUMMARY ..... 3**

**2. INTRODUCTION ..... 3**

**3. PASSWORD MANAGER EVALUATION ..... 4**

3.1 PURPOSE ..... 4
3.2 SELECTION CRITERIA ..... 4
3.3 OPEN SOURCE SOLUTIONS ..... 4
***3.3.1 KeePass*** ..... *4*
***3.3.2 Passbolt*** ..... *5*
***3.3.3 Padloc*** ..... *5*
3.4 COMMERCIAL SOLUTIONS ..... 6
***3.4.1 1Password*** ..... *6*
***3.4.2 LastPass*** ..... *6*
***3.4.3 Keeper*** ..... *7*

**4. TECHNICAL ANALYSIS ..... 7**

4.1 SECURITY ARCHITECTURE ..... 7
*4.1.1 Open Source Password Manager (KeePass, Passbolt, Padloc)* ..... *7*
*4.1.2 Commercial Password Manager (1Password, LastPass, Keeper)* ..... *8*
4.2 PLATFORM COMPATIBILITY ..... 9
4.3 DEPLOYMENT FLEXIBILITY ..... 10
4.4 COST-BENEFIT CONSIDERATIONS ..... 10

**5. RECOMMENDATIONS ..... 11**

5.1 OPEN SOURCE PASSWORD MANAGER (KEEPASS) ..... 11
5.2 COMMERCIAL PASSWORD MANAGER (1PASSWORD) ..... 11

**6. MULTI-FACTOR AUTHENTICATION (MFA) ..... 11**

6.1 MFA FACTORS AND STRATEGIC IMPLEMENTATION ..... 11
6.2 ANALYSIS OF BIOMETRIC RISKS ..... 12
6.3 ANALYSIS OF BIOMETRIC MFA ATTACKS ..... 12

**7. EMERGING AUTHENTICATION TECHNOLOGIES ..... 12**

7.1 EMERGING TECHNOLOGY AND STRATEGIC DEFENSE ..... 12
7.2 FEASIBILITY ANALYSIS AND ZERO TRUST ..... 13

**8. CONCLUSION ..... 13**

**9. REFERENCES ..... 13**

# 1. Summary

This report identifies key vulnerabilities facing USave, a UK-wide retail chain. It reviews current major threats and recommends the urgent adoption of the following measures:

i. Password managers
ii. Multi-factor authentication (MFA)
iii. Emerging Technologies (Passkeys)

Implementing these solutions will reduce the risk of human error and significantly improve USave's defences against identity-based attacks.

# 2. Introduction

It is very important for people to authenticate their work in security in modern distributed retail systems [1]. It protects data from breaches, unauthorized access and fraud, ensuring its safety and availability. For retailers like USave, having access to real-time data is crucial, as customer value depends on it. Poor access controls result in lost sales, stolen funds, damaged reputation and disruption.

In April 2025, UK retailers Marks and Spencer (M&S) and Co-op experienced ransomware attacks due to weak authentication. These attacks locked companies out of critical systems until they paid ransom. M&S reported losses of between £300 and £440 million.

Most importantly, the breaches revealed that the primary failure was not technical but was a result of criminals exploiting the human element in identity verification. The M&S attack involved social engineering.

# 3. Password Manager Evaluation

## 3.1 Purpose

Authentication underpins retail security. Password managers support ISO 27001 compliance and Cyber Essentials, which are essential for USave's secure, scalable operations. USave should directly compare open-source and commercial products to select the most effective solution for its needs.

## 3.2 Selection Criteria

USave uses several criteria to evaluate password managers. First, the *security architecture* must ensure technical controls for confidentiality and integrity. It is a primary concern for the Information Security (InfoSec) management team. Furthermore, *platform compatibility* ensures authentication works uniformly across all store locations and systems. *Deployment flexibility* enables the solution to support Systems-Specific Policies (SysSPs) for data storage and access. Assessing *Known Vulnerabilities* supports risk management strengths and vendor accountability. Finally, cost-benefit analysis is a wise resource allocation and will help maximize value in line with the organization's goals. These guide the selection of three open source and three commercial password managers for further analysis.

## 3.3 Open Source Solutions

### 3.3.1 KeePass

#### *3.3.1.1 Description*

KeePass Password Safe is a free and lightweight encryption tool released as open source. Zhang, Hong and Hu state that it stores user credentials in a KDBX file, an encrypted database format. Users only need to remember a single master password to access all credentials, eliminating the need for separate passwords per account. KeePass also features a strong password generator and relies on advanced encryption algorithms such as AES and Twofish to protect data [2].

#### *3.3.1.2 Rationale*

KeePass enhances operational resilience within USave's authentication framework. For example, the ransomware attack on M&S exposed vulnerabilities in its cloud authentication system, disrupting its online services. As an offline backup, KeePass enables IT staff to access recovery credentials during network outages. Additionally, its open source code allows USave experts to review it for data sovereignty compliance [2].

### 3.3.2 Passbolt

#### *3.3.2.1 Description*

Passbolt is also an open-source password manager developed by Kevin Muller, Diego Lendoiro, Remy Bertot and Cedric Alfonsi with later contributions from the GitHub community. It lets teams securely share passwords through a web application compatible with Firefox and Chrome. The platform was built using JavaScript, PHP and Shell scripting. Passbolt uses the OpenPGP encryption standard to protect data within trusted and closed groups [3].

#### *3.3.2.2 Rationale*

Passbolt solves the social engineering threat seen in the M&S case, where attackers posed as IT staff to steal help desk credentials. Usave requires that all password sharing occur with Passbolt's encrypted system, thereby eliminating the risks associated with email exchanges. This approach secures credentials, reduces leaks and supports centralized management across multiple locations [3].

### 3.3.3 Padloc

#### *3.3.3.1 Description*

Luevanos, Elizarraras, Hirschi and Yeh describe Padloc as a simple, open-source password manager. It is built on Electron and Polymer, using JavaScript, HTML and CSS. It ensures compatibility with Windows, macOS, Android and iOS. Padloc enhances security by logging out after one minute of inactivity. It also offers secure cloud syncing with its "Padloc Cloud" features [3].

#### *3.3.3.2 Rationale*

Padloc meets USave's need for a secure password solution for retail employees. IT staff may prefer complex tools like KeePass; store employees gain from Padloc's ease and strong security. Its automatic logout protects shared terminals when employees serve customers. These features provide USave centralized control over sensitive resources, meeting the case study's requirements [3].

## 3.4 Commercial Solutions

### 3.4.1 1Password

#### *3.4.1.1 Description*

1Password is developed by AgileBits Inc. It uses a "two-key" security system. It requires both a master password and a 44-character "Secret Key" which stored on the user's computer. Both keys are required to open the password vault, since the encryption key made from them. This design protects against offline attacks after server breaches [4]. 1Password is available on macOS, Windows, iOS and Android [5].

#### *3.4.1.2 Rationale*

1Password is selected for its proven strong protection against offline guessing attacks, even in the event of a server compromise. Instead of relying solely on a master password, 1Password uses a unique "two-key mechanism" that combines the master password with a locally stored and high-entropy key [4].

### 3.4.2 LastPass

#### *3.4.2.1 Description*

LastPass is a commercial password manager for businesses. It uses a cloud-based SaaS model. Browser extensions allow vaults to sync across devices. Enterprise IT teams are the main users. LastPass Enterprise supports over 33,000 businesses [6].

#### *3.4.2.2 Rationale*

LastPass Enterprise suits Usave due to features like "secure sharing" and "centralized admin control". Store managers can entrust access without revealing credentials. IT teams manage accounts centrally. It adds value

through “automated reporting”, providing executives with key security visibility. LastPass performs regular audits and learns from breaches [6].

### 3.4.3 Keeper

#### *3.4.3.1 Description*

Keeper is a popular password manager for multiple platforms that uses static password generation, creating 20-character passwords with diverse punctuation. Keeper autofilled credentials into unrelated website forms, exposing confidential information and locking users out of their data after the free trial ends [8].

#### *3.4.3.2 Rationale*

Keeper is chosen for Usave to enable direct comparison of password formats and not performance. The goal was to see if punctuation in Keeper’s default passwords affects website compatibility. This design clarifies whether punctuation yields different outcomes across platforms [8].

# 4. Technical Analysis

## 4.1 Security Architecture

### 4.1.1 Open Source Password Manager (KeePass, Passbolt, Padloc)

- **KeePass** is designed as a strictly local “trust-no-one” architectural model. It relies on strong encryption algorithms such as AES-256 or Twofish to keep information safe. Key derivation is achieved by combining MasterSeed and TransformSeed values, with computationally intensive hashing to mitigate brute-force attacks. Additionally, the integrity of data safeguarded via a 32-byte “StartBytes” pre-decryption verification mechanism [7].

- **Passbolt** is built for teamwork and uses the OpenPGP standard with GnuPG to help groups share encrypted information. While it aims to balance trust between users and the system, there are a few security, such as storing usernames in plain text and using less secure

encryption methods. These issues could make users' data less safe than intended [2].

- **Padloc** takes a web-first approach, using frameworks such as Electron and Polymer. It has a handy Auto Lock feature to keep data safe, but there is a catch: Padloc's system considers short, 7-character passwords strong, which goes against current password security practices [2].

### 4.1.2 Commercial Password Manager (1Password, LastPass, Keeper)

- **1Password** is designed to keep master password extra safe and it never actually sends the main password over the Internet. Instead, it uses the Secure Remote Password protocol (innovative system). It combines the password with stored 128-bit secret key, a method formally verified under the Universal Composability (UC) framework to prevent offline attacks [4].

- **LastPass** operates on a host-proof model that uses AES-256 encryption and SHA-256 hashing. Decryption occurs locally to maintain a zero-knowledge boundary. Crucially for Usave, its architecture integrates directly with Microsoft Active Directory. It allows the authentication layer to be offloaded to the enterprise identity provider while keeping the cryptographic vault keys isolated on the user's device [6].

- **Keeper's** security architecture, through its password-generation mechanism, uses a static approach: it applies the same password rules to all sites rather than tailoring them to each website's specific requirements. By default, Keeper generates 20-character passwords that include letters, digits and punctuation. The punctuation often causes problems [8].

## 4.2 Platform Compatibility

| Solution | Support Profile | Strategic Analysis |
|---|---|---|
| KeePass | Windows | Relying on unofficial ports for mobile and Mac introduces a supply chain trust gap with no clear vendor accountability [7]. |
| Passbolt | Web Browsers (Google Chrome and Firefox) | The platform lacks native desktop and mobile applications and remains functionally immature for Usave's offline or non-browser workflows.[2] |
| Padloc | Windows, macOS, Android, iOS | Passbolt covers core Usave devices, enabling seamless switching between back-office and floor tasks. Linux's absence is a minor gap. [2] |
| 1Password | all major platforms (cloud sync) | 1Password offers broad compatibility, allowing Usave to enforce a single security standard across its entire distributed environment. It provides security for both legacy back office PCS and mobile inventory devices. [4] |
| LastPass | all major operating systems, mobile platforms, web browsers | LastPass covers the full hardware ecosystem, from back-office desktops to mobile inventory tablets. This unified coverage ensures consistent security standards across the chain and enables staff to move seamlessly between devices, avoiding the need to juggle different tools for each operating system. [6] |
| Keeper | Android, Windows, iOS, macOS | Keeper is the most popular standalone password manager with consistent password generation across major operating systems. [8] |

## 4.3 Deployment Flexibility

***KeePass*** operates strictly locally and offline [7]. It requires no central server and features a lightweight 4.10MB installer that supports legacy hardware. However, its 476 KB of database files per 100 passwords is less efficient than some competitors. ***Passbolt*** and ***Padloc*** also support self-hosting but are architecturally complex [2]. ***Passbolt*** uses Docker and MySQL, and is affected by "trust all keys" vulnerabilities. ***Padloc*** requires a heavier stack with PostgreSQL, Redis and Node.js [2]. Commercial tools like ***LastPass*** and ***1Password*** focus on enterprise scalability. ***LastPass*** offers Active Directory compliance [4]. While ***1Password*** employs a Dual-Key architecture to protect data even if the server is compromised, some metadata may still leak [6]. ***Keeper*** is available as a standalone app and as a browser extension. Credentials can be synchronized and accessed via the mobile app. It provides an alternative access point if the browser extension is not available [8].

## 4.4 Cost-Benefit Considerations

***KeePass*** is free and open source with strong local encryption, but requires manual, error-prone synchronization, which increases friction for non-technical users [2, 6]. ***Passbolt*** and ***Padloc*** are open-source options for different needs: ***Passbolt*** is strong for team sharing but requires complex protocols, while ***Padloc*** offers cloud convenience but has critical vulnerabilities that could allow data reset [7, 4, 3]. On the commercial side, ***1Password*** stands out for its robust 'Two-Secret' security model, which justifies its price with strong vault protection [4]. ***LastPass*** is favored for broad compatibility and administrative tools, but it is a frequent target and introduces extension-related risks [6]. ***Keeper***'s "zero-knowledge" architecture is ready to use without complex setup, though users may be frustrated by bugs such as incorrect autofill or conflicts with strict password policies during registration [8].

# 5. Recommendations

## 5.1 Open Source Password Manager (KeePass)

KeePass is a suitable specialist “break glass” tool for IT staff. The M&S ransomware attack showed that network outages can disrupt cloud services. KeePass’s offline design keeps critical recovery keys available, even if systems are locked down. It is more technically mature than Passbolt and Padloc, which had weak defaults and plaintext issues. KeePass uses AES-256 or Twofish encryption to protect Usave’s most sensitive infrastructure assets [7].

## 5.2 Commercial Password Manager (1Password)

1Password is recommended for Usave’s workforce. Its “Two-Secret” architecture uses a Master Password and a local 128-bit Secret Key to secure vaults. It protects data even if cloud servers are breached. The setup directly addresses data exposure risks, as seen in the Co-op incident. 1Password uses “zero-knowledge” sharing, allowing IT to grant access without revealing staff passwords. Unlike Keeper, 1Password works consistently on both Windows and mobile devices, helping standardize security [4].

# 6. Multi-Factor Authentication (MFA)

## 6.1 MFA Factors and Strategic Implementation

To secure Usave, authentication must use more than static passwords. Therefore, the system will use multi-factor authentication (MFA). Knowledge-based schemes are weak because users often reuse credentials or choose weak passwords, thereby increasing the attack surface and the risk of compromise. In response, USave will use a tiered MFA solution: administrators will use hardware tokens for strong authentication while store staff will authenticate with app-based biometrics, streamlining their workflow and eliminating key management. This approach seeks to balance security and usability for different user groups [9].

## 6.2 Analysis of Biometric Risks

While biometric authentication enhances usability, it introduces specific risks that Usave must actively mitigate. Facial recognition systems can be susceptible to “presentation attacks”, where an adversary uses a photograph to trick the scanner. Similarly, voice recognition features can be compromised by “spoofing” attacks using synthesized audio recordings. Additionally, environmental factors in a retail setting, such as staff wearing gloves, can render fingerprint scanners unusable, potentially disrupting store operations. To counter these threats, USave’s mobile application must strictly enforce “liveness detection” to verify the user’s physical presence and neutralize spoofing attempts [9].

## 6.3 Analysis of Biometric MFA Attacks

- **Facial recognition:** an efficient MFA for retail staff, but it is vulnerable to presentation attacks. Standard systems rely on landmark-based image analysis, such as displaying a high-resolution photograph. In targeted attacks, an adversary could collect social media photos to bypass authentication [10].
- **Voice recognition:** allows touchless authentication but is susceptible to sophisticated spoofing. Attackers might capture a user’s voice, then forge a message using synthesized speech or by replaying a recorded phrase. For USave, a critical risk arises if warehouse access relies on voice commands; an attacker could use AI-generated audio to impersonate a senior manager [10].

# 7. Emerging Authentication Technologies

## 7.1 Emerging Technology and Strategic Defense

To address social engineering, including recent M&S cases, **Passkeys** are recommended**,** which use the FIDO2/WebAuthn standards. Passkeys keep private keys exclusively on users’ devices and never transmit them to servers. This approach mitigates credential exposure during IT support and eliminates password reset vulnerabilities. These credentials are non-

exportable and cannot be shared verbally, which reduces key ransomware risks [11].

## 7.2 Feasibility Analysis and Zero Trust

Device portability causes operational challenges for retailers like USave. Device-specific passkeys tied to a manager's iPhone make shared authentication at POS terminals rugged for floor staff. We recommend a Hybrid Authentication Model. Headquarters employees should use biometric devices for secure access on personal devices. Shop floor staff Roaming Authenticators, such as FIDO2 hardware security keys, for secure logins at shared terminals. This approach maintains core workflows while moving Usave toward Zero Trust, verifying user identity and device context rather than static credentials [11].

# 8. Conclusion

USave must strengthen defenses against identity-based attacks and social engineering, threats that are also relevant to M&S and Co-op. Deploy KeePass as an offline disaster recovery tool, and implement 1Password for the workforce. Its "Two-Secret" architecture provides robust protection. Introducing MFA strategy and adopting FIDO2 Passkeys to reduce credential theft and phishing.

# 9. References


[1] Michael Burrows, Martin Abadi, and Roger Needham. 1990. A logic of authentication. ACM Trans. Comput. Syst. 8, 1 (Feb. 1990), 18–36. https://doi.org/10.1145/77648.77649

[2] hengwei zhang, jingxin hong, and jun hu. 2016 "analysis of encryption mechanism in keepass password safe 2.30" 10th IEEE International conference on anti-counterfeiting, Security, and identification (ASID) (MAR. 2017). https://doi.org/10.1109/icasid.2016.7873914

[3] CARLOS LUEVANOS, JOHN ELIZARRARAS, KHAI HIRSCHI, AND JYH-HAW YEH. 2017. "ANALYSIS ON THE SECURITY AND USE OF PASSWORD MANAGERS" 18TH INTERNATIONAL CONFERENCE ON PARALLEL AND DISTRIBUTED COMPUTING, APPLICATIONS AND TECHNOLOGIES (PDCAT) (MARCH 2018). HTTPS://DOI.ORG/10.1109/PDCAT.2017.00013

[4] YIHE DUAN, DING WANG, AND YANDUO FU. 2025. SECURITY "ANALYSIS OF MASTER-PASSWORD-PROTECTED PASSWORD MANAGEMENT PROTOCOLS" 2025 IEEE SYMPOSIUM ON SECURITY AND PRIVACY (SP) 701-719. HTTPS://DOI.ORG/10.1109/SP61157.2025.00050

[5] MCCARNEY DANIEL. 2013. PASSWORD MANAGERS: COMPARATIVE EVALUATION, DESIGN, IMPLEMENTATION AND EMPIRICAL ANALYSIS. MASTER'S THESIS. CARLETON UNIVERSITY, OTTAWA, CANADA.

[6] MIKA QVINTUS. 2018. EVALUATING PASSWORD MANAGERS FOR ENTERPRISES. BACHELOR'S THESIS. LAUREA UNIVERSITY OF APPLIED SCIENCES, VANTAA, FINLAND.

[7] HARRIS FLOURENTZOS. 2018. A USABILITY EVALUATION AND RE-DESIGN OF THE PASSWORD MANAGER SOFTWARE KEEPASS2. MASTER'S THESIS. UNIVERSITY OF EDINBURGH, EDINBURGH, SCOTLAND.

[8] ADRYANA HUTCHINSON, JINWEI TANG, ADAM J. AVIV, AND PETER STORY. 2024. "MEASURING THE PREVALANCE OF PASSWORD MANAGER ISSUES USING IN-SITU EXPERIMENTS" SYMPOSIUM ON USABLE SECURITY AND PRIVACY (USEC) (FEB. 2024). HTTPS://DOI.ORG/10.14722/USEC.2024.23094

[9] JÉRÔME PAGÈS. 2005. COLLECTION AND ANALYSIS OF PERCEIVED PRODUCT INTER-DISTANCES USING MULTIPLE FACTOR ANALYSIS: "APPLICATION TO THE STUDY OF 10 WHITE WINES FROM THE LOIRE VALLEY" FOOD QUALITY AND PREFERENCE 16, 7 642-649 (OCT. 2005) HTTPS://DOI.ORG/10.1016/J.FOODQUAL.2005.01.006

[10] SACHIN SURYAWANSHI. 2025. "SECURING THE MODERN WEB: A COMPREHENSIVE EXPLORATION OF WEB API AUTHENTICATION AND FUTURE TRENDS" TECHRXIV (JAN. 2025) HTTPS://DOI.ORG/10.36227/TECHRXIV.173835579.93447825/V1

[11] DR. A. SHAJI GEORGE. 2024. "THE DAWN OF PASSKEYS: EVALUATING A PASSWORDLESS FUTURE. PARTNERS UNIVERSAL INNOVATIVE RESEARCH PUBLICATION. 2, 1 (FEB. 2024), 202-220. HTTPS://DOI.ORG/10.5281/ZENODO.10697886